Network Security 2
Rubric 5
Network Security Operations
The project must include proper network traffic capture with basic evidence collection procedures. Security configurations must be tested on at least one network device with validation of security settings. Basic compliance checking must be performed against a simple security checklist. A basic incident analysis must be conducted using a provided scenario with documentation of findings. All activities must include screenshots and simple reports.

To satisfy **Rubric 5: Network Security Operations** inside my VirtualBox environment using **OPNsense, Kali, and Ubuntu**, you can execute a highly organized, practical simulation. This guide breaks down the four core requirements—traffic capture, configuration validation, a compliance checklist, and an incident scenario—into actionable laboratory steps.

---

1. Network Traffic Capture & Evidence Collection

To demonstrate proper forensics, you will use **Kali Linux** to sniff a simulated attack or baseline authentication traffic hitting your OPNsense firewall, preserving the packet data using standard evidence chain criteria.

Step-by-Step Execution

1. Open a terminal on your **Kali Linux VM**.
2. Run `tcpdump` to capture traffic on your active interface (e.g., `eth0`), specifying a write file to generate raw evidence:
   bash

```
None

sudo tcpdump -i eth0 -vvv -w hq_traffic_capture.pcap
```

3. From your **Ubuntu VM**, generate network traffic (e.g., ping the OPNsense gateway or log into the Captive Portal).
4. Stop the capture on Kali using `Ctrl + C`.
5. Generate a cryptographic hash of your packet capture immediately to guarantee data integrity (evidence preservation):

   bash

```
None


sha256sum hq_traffic_capture.pcap >
hq_traffic_capture.pcap.sha256
```

6. Use code with caution.

📸 ***Screenshot Requirement:*** *Capture the terminal screen showing the* `tcpdump` *completion and the output of the* `sha256sum` *command.*

📸 ***Evidence Screenshot:*** *Open the* `.pcap` *file inside* ***Wireshark*** *on Kali, filter by* `ip.addr == 192.168.10.1`*, and screenshot the readable packet headers.*

---

2. Device Testing & Validation of Security Settings

You must actively test and prove that your firewall configurations (such as the Captive Portal or RBAC tiers created earlier) successfully block or permit traffic as intended.

Verification Tests

- **Test A (Captive Portal Enforcer):** Prior to logging in via the Ubuntu browser, attempt to resolve a web connection or run `curl -I http://example.com` in the terminal.

- **Test B (VPN Connectivity):** From an asset in the HQ subnet, ping an asset or interface in the simulated Branch subnet (`192.168.20.1`).

📸 ***Validation Screenshot 1:*** *A terminal screen showing `curl` being intercepted/redirected to the OPNsense Captive Portal IP address.*

📸 ***Validation Screenshot 2:*** *A successful `ping -c 4 192.168.20.1` illustrating packets successfully routing through the encrypted IPsec tunnel.*

3. Basic Compliance Checklist

Copy this foundational checklist into your project report to document your lab's alignment with basic hardening frameworks (e.g., NIST SP 800-53 or CIS Controls).

Compliance Check	Status (Pass/Fail)	Evidence/Target Component
Default Credentials Changed	**PASS**	Default `root`/`opnsense` account changed to unique administrative passphrases.
Least Privilege Enforced	**PASS**	Created a restricted `Auditors` group lacking configuration permissions.
Data in Transit Encrypted	**PASS**	Site-to-Site traffic secured using AES-256 IPsec phase tunnels.
Network Access Control	**PASS**	Captive Portal authentication active on `HQ_LAN` to restrict unknown endpoints.

Secure Management Access	**PASS**	Web GUI interface restricted to HTTPS rather than unencrypted HTTP.

> Network Access & Authentication The project must demonstrate basic Network Access Control implementation in a lab environment. Identity-based access must be configured using username/password or certificate authentication. A basic site-to-site VPN must be configured between two virtual networks. Role-based access control must be implemented for at least two different user types. All configurations must include screenshots and basic setup documentation.

To successfully build this project in a lab environment, you can use industry-standard platforms like Cisco Packet Tracer, GNS3, or pfSense/OPNsense.

Below is a complete, structured lab guide that satisfies all your project criteria: Network Access Control (NAC), Identity-Based Authentication, Site-to-Site VPN, and Role-Based Access Control (RBAC).

---

1. Lab Architecture & Topology

For a robust simulation, structure your virtual environment with two main locations: **Headquarters (HQ)** and **Branch Office (BO)**.

text

```
None
[ HQ Local Network ]            [ Internet Simulation ]
[ Branch Local Network ]

  - Admin Client                  (ISP Router / Cloud)
- Staff Client
```

```
  - Executive Client                          |
|


        |                                     |
|
  [ HQ Firewall/Router ] <======= Site-to-Site VPN
=======> [ Branch Firewall/Router ]

        |

  [ RADIUS / AAA Server ]
```

Use code with caution.

---

2. Identity-Based Access & Network Access Control (NAC)

Implement **IEEE 802.1X** on your HQ Switch ports to prevent unauthorized physical or virtual devices from bridging into your network.

Core Logic

- Unauthenticated devices are dropped into a **Guest / Remediation VLAN**.
- Successfully authenticated devices are dynamically mapped to production network zones.

Setup Documentation (Cisco IOS Example)

1. **Configure the AAA Server Link:** Tell the network device where to look for credentials.
   text

```
None

aaa new-model

radius-server host 192.168.10.50 key MyRadiusSecret123

aaa authentication dot1x default group radius
```

2. Use code with caution.
3. **Enable 802.1X Globally and per Port:**
   text

```
None

dot1x system-auth-control

interface GigabitEthernet0/1

 switchport mode access

 authentication port-control auto

 dot1x pae authenticator
```

4. Use code with caution.

📸 ***Screenshot Placement:*** *Captures of the RADIUS server logs demonstrating successful identity verification via username/password or certificate handshakes.*

---

3. Role-Based Access Control (RBAC)

You need to segregate user capabilities into at least two distinct user tiers to satisfy least-privilege access rules.

User Type	Access Scope	Implementation Method
Network Administrator	Full read/write to network hardware and management planes.	Assigned to **Privilege Level 15** or a specific Admin Active Directory group.
General Staff	Read-only network access; internet browsing only.	Assigned to **Privilege Level 1** or a restricted Staff VLAN with explicit ACLs.

Example Cisco RBAC (Privilege Tiers) Configuration

text

```
None

username net_admin privilege 15 secret AdminSecurePass!

username gen_staff privilege 1 secret StaffSimplePass!


! Restrict staff from executing global configuration changes

privilege exec level 1 show running-config
```

Use code with caution.

📸 ***Screenshot Placement:*** *Snaps of the CLI terminal showing* `net_admin` *accessing* `configure terminal`*, contrasted against* `gen_staff` *receiving a "Command rejected" warning.*

---

4. Basic Site-to-Site VPN (IPsec)

Establish an encrypted tunnel between the HQ Gateway and the Branch Gateway over an untrusted public space. [1]

Step-by-Step Setup Profile

1. **Phase 1 (IKEv2 / ISAKMP):** Negotiate the control channel framework.
    - **Encryption:** AES-256
    - **Hash:** SHA-256
    - **Diffie-Hellman Group:** Group 14 (2048-bit)
    - **Authentication:** Pre-shared Key (PSK) or Digital Certificates [1, 2, 3]
2. **Phase 2 (IPsec Data Tunnel):** Negotiate how payload traffic is encrypted.
    - **Transform Set:** ESP-AES-256 and ESP-SHA-256-HMAC [1]

Setup Documentation (HQ Router Example)

text

```
None
crypto isakmp policy 10
 encr aes 256
 hash sha256
 authentication pre-share
 group 14
crypto isakmp key TunnelSecretKey address 203.0.113.2
```

```
crypto ipsec transform-set HQ-BO-SET esp-aes 256
esp-sha256-hmac


ip access-list extended VPN-TRAFFIC

 permit ip 192.168.10.0 0.0.0.255 192.168.20.0
0.0.0.255


crypto map vpn-map 10 ipsec-isakmp

 set peer 203.0.113.2

 set transform-set HQ-BO-SET

 match address VPN-TRAFFIC


interface GigabitEthernet0/0

 crypto map vpn-map
```

Use code with caution.

(Note: Change the target IP addresses and mirror the configuration symmetrically on the Branch Gateway router.)

📸 ***Screenshot Placement:*** *Run `show crypto isakmp sa` and `show crypto ipsec sa` on the routers. Take a screenshot showing the tunnel status reading `QM_IDLE` or `ACTIVE`.*

---

5. Finalizing Your Submission Documentation

When assembling your final lab report, organize it directly around your grading rubric:

1. **Topology Diagram:** A logical architecture drawing labeling IP configurations, VLAN numbers, and interface IDs.
2. **Step-by-Step Execution Verification:**
    - A screenshot of a successful `ping` or `traceroute` traversing the site-to-site VPN.
    - Proof of a Wireshark capture highlighting that data payloads over the WAN link are unreadable and fully encrypted inside **ESP packets**.
    - A verification snapshot of your identity database (Active Directory, FreeRADIUS, or Local database).

To help tailor this documentation further, let me know:

- What **specific software platform** are you using for your lab environment? (e.g., Cisco Packet Tracer, GNS3, VMware/pfSense, Azure, AWS?)
- Do you prefer your identity-based access to be configured via **Username/Password (RADIUS/TACACS+)** or via **X.509 Certificates (PKI)**?

AI can make mistakes, so double-check responses

- YouTube
  Connect Your On-Prem Network to Azure in 20 Minutes - YouTube
  Jun 29, 2025 — next we can use a pre-shared key or a key vault certificate.
  
- Palo Alto Networks
  What Is a Site-to-Site VPN? - Palo Alto Networks

Define crypto profiles for IKE (for phase 1) and IPSec (for phase 2). Configure the IPSec tunnels.

- Palo Alto Networks
  What Are the Different Types of VPN? - Palo Alto Networks
  Remote Access VPN | User connects to a private network |. SSL VPN | Devices establish a secure remote access VPN connection with a...



Show all

Network Access & Authentication The project must demonstrate basic Network Access Control implementation in a lab environment. Identity-based access must be configured using username/password or certificate authentication. A basic site-to-site VPN must be configured between two virtual networks. Role-based access control must be implemented for at least two different user types. All configurations must include screenshots and basic setup documentation. I want to go with open sense since my home lab is made up of VirtualBox , kali, ubuntu and the firewall

Since you are building your lab inside **VirtualBox** using **OPNsense**, **Ubuntu**, and **Kali**, you can create a highly realistic enterprise simulation. OPNsense will act as your edge firewall and identity provider, while Ubuntu and Kali act as your corporate assets and penetration testing/audit endpoints.

---

1. VirtualBox Network Architecture

To isolate traffic properly and simulate a true Site-to-Site environment on a single physical host, configure your VirtualBox network adapters using **Internal Networks**.

Virtual Machine	Adapter 1 (WAN / Management)	Adapter 2 (HQ LAN)	Adapter 3 (Branch LAN)
OPNsense Firewall	**Bridged** or **NAT** (Internet Access)	**Internal Network**: `hq_lan`	**Internal Network**: `branch_lan`
Ubuntu Client (HQ Staff)	**Internal Network**: `hq_lan`	None	None
Kali Linux (HQ Admin)	**Internal Network**: `hq_lan`	None	None

Note: In OPNsense, we will assign the `branch_lan` interface to act as a simulated remote branch office so you can build a loopback Site-to-Site VPN directly inside the same firewall instance.

---

2. Identity-Based Access & Captive Portal (NAC)

Since true 802.1X dynamic VLAN assignment can be complex to simulate inside VirtualBox without a managed virtual switch, the industry-standard way to enforce Network Access Control (NAC) in OPNsense is via a **Captive Portal with Identity Authentication**.

Setup Steps

1. Navigate to **Services** ➡️ **Captive Portal** ➡️ **Administration**.
2. Click the **+** button to create a new zone named `HQ_NAC`.
3. Set the **Interfaces** to `HQ_LAN`.
4. Set the **Authentication Server** to `Local Database` (or a RADIUS server if you install one on Ubuntu).
5. Click **Save** and **Apply**.

📸 ***Screenshot Requirement:*** *Take a snapshot of the OPNsense Captive Portal administration screen showing the zone enabled on the HQ_LAN interface.*

📸 ***Verification Screenshot:*** *Open a browser on the Ubuntu VM. Try to go to any website, and capture the OPNsense login splash page blocking internet access until credentials are typed.*

---

3. Role-Based Access Control (RBAC) in OPNsense

You need to create two distinct administrative user tiers within the OPNsense web GUI to satisfy the RBAC requirement.

User Definition Matrix

- **Network Admin (`net_admin`):** Full read/write access to all firewall settings, VPNs, and system dashboards.
- **Security Auditor (`sec_auditor`):** Read-only access to view logs, firewall rules, and VPN status. No modification rights.

Setup Steps

1. Navigate to **System ➡️ Access ➡️ Groups**. Click **+** to add a group named `Auditors`.
2. Edit the `Auditors` group, scroll to **Assigned Privileges**, and check the boxes *only* for pages containing "Diagnostics", "Log Files", and "Status". Do not grant "All pages" or configuration rights.
3. Navigate to **System ➡️ Access ➡️ Users**.
4. Create user `net_admin` and add them to the default `admins` group.
5. Create user `sec_auditor` and add them to the `Auditors` group.

📸 ***Screenshot Requirement:*** *Capture the "Assigned Privileges" window of the `Auditors` group showing restricted page permissions.*

📸 ***Verification Screenshot:*** *Log in as `sec_auditor` from your Kali VM browser, attempt to click "Save" on a firewall rule, and screenshot the resulting access denied/read-only alert.*

---

4. Basic Site-to-Site VPN (IPsec)

To fulfill a Site-to-Site VPN using a single OPNsense firewall, you will configure a "loopback" or "cross-interface" IPsec tunnel between your simulated `hq_lan` network subnet (e.g., `192.168.10.0/24`) and your `branch_lan` network subnet (e.g., `192.168.20.0/24`).

Step-by-Step Profile

1. Navigate to **VPN ➡️ IPsec ➡️ Tunnel Settings**. Click **+** to create a Phase 1.
2. **Phase 1 Configuration (HQ Side):**
    - **Connection method:** Start immediate
    - **Key Exchange:** IKEv2
    - **Remote gateway:** IP address of your Branch WAN/Interface link
    - **Authentication:** Pre-Shared Key (Set a strong key like `OPNsenseVPNSecureKey2026!`)
    - **Encryption:** AES-256 | **Hash:** SHA256 | **DH Group:** 14 (2048 bit)
3. **Phase 2 Configuration (Data Tunnel):**
    - Click the **+** button inside your new Phase 1 entry to add Phase 2.
    - **Mode:** Tunnel IPv4
    - **Local Network:** LAN subnet (`192.168.10.0/24`)
    - **Remote Network:** Type in your Branch subnet (`192.168.20.0/24`)
    - **Protocol:** ESP
    - **Encryption:** AES-256 | **Hash:** SHA256

(Note: Create a mirrored IPsec Tunnel configuration reversing the Local and Remote networks to represent the Branch side connecting back to HQ).

📸 ***Screenshot Requirement:*** *Navigate to **VPN ➡️ IPsec ➡️ Status Overview**. Take a screenshot showing both Phase 1 and Phase 2 entries highlighted with green checkmarks/icons showing an **INSTALLED / CONNECTED** state.*

---

5. Final Documentation Outline

When you compile your final report, structure it around these clean sections:

1. **Topology Diagram:** A screenshot of your VirtualBox network configuration settings or a drawn diagram showing how `hq_lan` and `branch_lan` connect through OPNsense.
2. **Identity Verification:** Your Ubuntu browser screenshot showing the Captive Portal redirect.
3. **RBAC Validation:** Side-by-side screenshots of the OPNsense dashboard menu options when logged in as `net_admin` versus `sec_auditor`.
4. **Traffic Audit:** Open a terminal on Kali Linux, run a ping across the VPN subnet, and take a screenshot of **OPNsense Firewall Logs (Firewall ➡️ Log Files ➡️ Live View)** showing traffic successfully passing through the IPsec interface.

Would you like help writing a bash script to automate configuring the network interfaces for your **Ubuntu** or **Kali** VMs so they match your target OPNsense subnets exactly?

> rubric 5 in network security 2. etwork Security Operations The project must include proper network traffic capture with basic evidence collection procedures. Security configurations must be tested on at least one network device with validation of security settings. Basic compliance checking must be performed against a simple security checklist. A basic incident analysis must be conducted using a provided scenario with documentation of findings. All activities must include screenshots and simple reports.

To satisfy **Rubric 5: Network Security Operations** inside your VirtualBox environment using **OPNsense, Kali, and Ubuntu**, you can execute a highly organized, practical simulation. This guide breaks down the four core requirements—traffic capture, configuration validation, a compliance checklist, and an incident scenario—into actionable laboratory steps.

---

1. Network Traffic Capture & Evidence Collection

To demonstrate proper forensics, you will use **Kali Linux** to sniff a simulated attack or baseline authentication traffic hitting your OPNsense firewall, preserving the packet data using standard evidence chain criteria.

Step-by-Step Execution

1. Open a terminal on your **Kali Linux VM**.
2. Run `tcpdump` to capture traffic on your active interface (e.g., `eth0`), specifying a write file to generate raw evidence:
   bash

```
None

sudo tcpdump -i eth0 -vvv -w hq_traffic_capture.pcap
```

3.
   Use code with caution.
4. From your **Ubuntu VM**, generate network traffic (e.g., ping the OPNsense gateway or log into the Captive Portal).
5. Stop the capture on Kali using `Ctrl + C`.
6. Generate a cryptographic hash of your packet capture immediately to guarantee data integrity (evidence preservation):
   bash

```
None

sha256sum hq_traffic_capture.pcap >
hq_traffic_capture.pcap.sha256
```

7.

Use code with caution.

📸 ***Screenshot Requirement:*** *Capture the terminal screen showing the* `tcpdump` *completion and the output of the* `sha256sum` *command.*

📸 ***Evidence Screenshot:*** *Open the* `.pcap` *file inside* ***Wireshark*** *on Kali, filter by* `ip.addr == 192.168.10.1`*, and screenshot the readable packet headers.*

---

2. Device Testing & Validation of Security Settings

You must actively test and prove that your firewall configurations (such as the Captive Portal or RBAC tiers created earlier) successfully block or permit traffic as intended.

Verification Tests

- **Test A (Captive Portal Enforcer):** Prior to logging in via the Ubuntu browser, attempt to resolve a web connection or run `curl -I http://example.com` in the terminal.
- **Test B (VPN Connectivity):** From an asset in the HQ subnet, ping an asset or interface in the simulated Branch subnet (`192.168.20.1`).

📸 ***Validation Screenshot 1:*** *A terminal screen showing* `curl` *being intercepted/redirected to the OPNsense Captive Portal IP address.*

📸 ***Validation Screenshot 2:*** *A successful* `ping -c 4 192.168.20.1` *illustrating packets successfully routing through the encrypted IPsec tunnel.*

---

3. Basic Compliance Checklist

Copy this foundational checklist into your project report to document your lab's alignment with basic hardening frameworks (e.g., NIST SP 800-53 or CIS Controls).

Compliance Check	Status (Pass/Fail)	Evidence/Target Component
Default Credentials Changed	**PASS**	Default `root`/`opnsense` account changed to unique administrative passphrases.
Least Privilege Enforced	**PASS**	Created a restricted `Auditors` group lacking configuration permissions.
Data in Transit Encrypted	**PASS**	Site-to-Site traffic secured using AES-256 IPsec phase tunnels.

Network Access Control	**PASS**	Captive Portal authentication active on `HQ_LAN` to restrict unknown endpoints.
Secure Management Access	**PASS**	Web GUI interface restricted to HTTPS rather than unencrypted HTTP.

---

4. Incident Analysis Report (Scenario-Based)

Since a standard scenario is required, use this industry-realistic event to build your incident documentation.

Incident Scenario

> **Context:** An external malicious actor attempts to brute-force the OPNsense Web GUI administration interface from the WAN network interface link.

Findings & Documentation Report

- **Incident Discovery:** Multiple failed login attempts for user account `root` detected within a 2-minute window originating from an external rogue IP address.
- **Analysis & Log Verification:** Review the live firewall logs by navigating to **System ➡️ Log Files ➡️ Backend** or looking at your `tcpdump`

capture file for excessive HTTPS connection handshakes from a single foreign IP.

- **Containment Strategy:** The OPNsense *sshlockout* / system-builtin brute protection automatically bans the source IP address after 5 failed authentication attempts.
- **Eradication / Post-Incident Action Plan:** Implement a firewall rule on the WAN interface that completely blocks access to the OPNsense management ports from all external IP addresses, allowing GUI access *only* from the trusted internal management network.

📸 ***Screenshot Requirement:*** *Navigate to* ***Firewall ➡️ Log Files ➡️ Live View*** *in OPNsense, filter for blocked connections or authentication failures, and snap the resulting security event logs.*